

Hands-on Experience

Mid-Term Exam Report

Target	seu.edu.bd
Assignment Date	5/5/2026
Tester	Sheikh Arman Karim Aditto
Batch	CADS003
Exam	Mid
Environment	VMware, Kali Linux, Parrot

Scenario 1 | Metasploit Post-Exploitation

Scenario No: 1 | Task Phase 1

The command used to discover hidden IP addresses is `meterpreter > arp`.

```
meterpreter > arp

ARP cache
```

IP address	MAC address	Interface
10.92.224.247	0e:3a:00:d2:6a:03	Intel(R) Wireless-AC 9462
10.92.224.255	ff:ff:ff:ff:ff:ff	Intel(R) Wireless-AC 9462
192.168.56.255	ff:ff:ff:ff:ff:ff	VirtualBox Host-Only Ethernet Adapter
192.168.67.255	ff:ff:ff:ff:ff:ff	VMware Virtual Ethernet Adapter for VMnet1
192.168.73.130	00:0c:29:64:cb:07	VMware Virtual Ethernet Adapter for VMnet8
192.168.73.255	ff:ff:ff:ff:ff:ff	VMware Virtual Ethernet Adapter for VMnet8
224.0.0.2	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.2	01:00:5e:00:00:02	Intel(R) Wireless-AC 9462
224.0.0.2	01:00:5e:00:00:02	Intel(R) Ethernet Connection (13) I219-V
224.0.0.22	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.22	01:00:5e:00:00:16	Intel(R) Wireless-AC 9462
224.0.0.22	01:00:5e:00:00:16	Microsoft Wi-Fi Direct Virtual Adapter
224.0.0.22	01:00:5e:00:00:16	Microsoft Wi-Fi Direct Virtual Adapter #2
224.0.0.22	01:00:5e:00:00:16	Intel(R) Ethernet Connection (13) I219-V
224.0.0.22	01:00:5e:00:00:16	VirtualBox Host-Only Ethernet Adapter
224.0.0.22	01:00:5e:00:00:16	VMware Virtual Ethernet Adapter for VMnet1
224.0.0.22	01:00:5e:00:00:16	VMware Virtual Ethernet Adapter for VMnet8
224.0.0.251	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.251	01:00:5e:00:00:fb	Intel(R) Wireless-AC 9462
224.0.0.251	01:00:5e:00:00:fb	VirtualBox Host-Only Ethernet Adapter
224.0.0.251	01:00:5e:00:00:fb	VMware Virtual Ethernet Adapter for VMnet1
224.0.0.251	01:00:5e:00:00:fb	VMware Virtual Ethernet Adapter for VMnet8
224.0.0.252	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.252	01:00:5e:00:00:fc	Intel(R) Wireless-AC 9462
224.0.0.252	01:00:5e:00:00:fc	Intel(R) Ethernet Connection (13) I219-V
224.0.0.252	01:00:5e:00:00:fc	VirtualBox Host-Only Ethernet Adapter
224.0.0.252	01:00:5e:00:00:fc	VMware Virtual Ethernet Adapter for VMnet1
224.0.0.252	01:00:5e:00:00:fc	VMware Virtual Ethernet Adapter for VMnet8
239.255.255.250	00:00:00:00:00:00	Software Loopback Interface 1
239.255.255.250	01:00:5e:7f:ff:fa	Intel(R) Wireless-AC 9462
239.255.255.250	01:00:5e:7f:ff:fa	Intel(R) Ethernet Connection (13) I219-V
239.255.255.250	01:00:5e:7f:ff:fa	VirtualBox Host-Only Ethernet Adapter
239.255.255.250	01:00:5e:7f:ff:fa	VMware Virtual Ethernet Adapter for VMnet1
239.255.255.250	01:00:5e:7f:ff:fa	VMware Virtual Ethernet Adapter for VMnet8
255.255.255.255	ff:ff:ff:ff:ff:ff	Intel(R) Wireless-AC 9462

Figure 1 — ARP cache output from the meterpreter session

Scenario 1 | Task Phase 2

The Metasploit post module I would use to suggest potential exploits for escalating is

```
msf6 > use post/multi/recon/local_exploit_suggester
```

```
meterpreter > getsystem
```

```
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: All pipe instances are busy.
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
[-] Named Pipe Impersonation (PrintSpooler variant)
```

Figure 2 — Output of the getsystem privilege-escalation attempt

Scenario 1 | Task Phase 3

The Metasploit module that allows to use the hash itself to authenticate to other machines is

```
msf > use exploit/windows/smb/psexec
```

```
msf exploit(multi/handler) > use exploit/windows/smb/psexec
[*] Using configured payload windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > 
```

Figure 3 — Loading the SMB psexec exploit module

Scenario 1 | Task Phase 4

The auxiliary module can be run to perform a TCP port scan on Target 2 from within the Metasploit framework is

```
msf > use auxiliary/scanner/portscan/tcp
```

```
msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.56.1
RHOSTS => 192.168.56.1
msf auxiliary(scanner/portscan/tcp) > set PORTS 4444
PORTS => 4444
msf auxiliary(scanner/portscan/tcp) > run
[*] 192.168.56.1 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > 
```

Figure 4 — TCP port scan executed against the target host

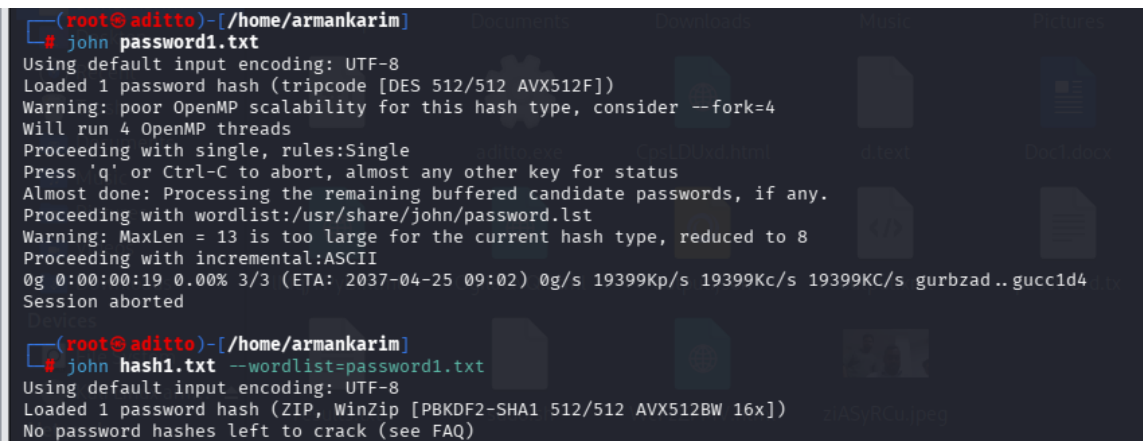
Scenario 2 | Password Attacks & Hash Cracking

Scenario 2 | Task Phase 1

\$1\$ means **MD5-based Unix/Linux password hash**. The command I would use to show the cracked password if already run the session,

```
john password1.txt
```

```
john hash1.txt --wordlist=password1.txt ( with export file )
```



```
(root@aditto) [/home/armankarim]
# john password1.txt
Using default input encoding: UTF-8
Loaded 1 password hash (tripcode [DES 512/512 AVX512F])
Warning: poor OpenMP scalability for this hash type, consider --fork=4
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Warning: MaxLen = 13 is too large for the current hash type, reduced to 8
Proceeding with incremental:ASCII
0g 0:00:00:19 0.00% 3/3 (ETA: 2037-04-25 09:02) 0g/s 19399Kp/s 19399Kc/s 19399KC/s gurbzad..gucc1d4
Session aborted

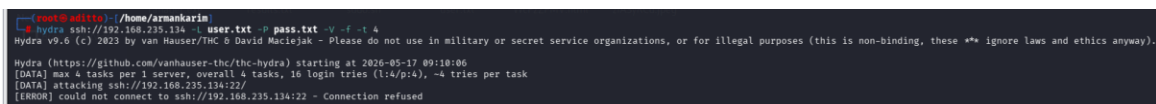
(root@aditto) [/home/armankarim]
# john hash1.txt --wordlist=password1.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 512/512 AVX512BW 16x])
No password hashes left to crack (see FAQ)
```

Figure 5 — John the Ripper cracking session output

Scenario 2 | Task Phase 2

The specific Hydra command to target the SSH service for user custom username list using custom password list, ensuring you use 4 parallel tasks to remain stealthy is,

```
hydra ssh://192.168.235.134 -L user.txt -P pass.txt -V -f -t 4
```



```
(root@aditto) [/home/armankarim]
# hydra ssh://192.168.235.134 -L user.txt -P pass.txt -V -f -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-17 09:10:06
[DATA] max 4 tasks per 1 server, overall 4 tasks, 16 login tries (1:4/p:4), ~4 tries per task
[DATA] attacking ssh://192.168.235.134:22/
[ERROR] could not connect to ssh://192.168.235.134:22 - Connection refused
```

Figure 6 — Hydra SSH brute-force attempt against the target

Scenario 2 | Task Phase 3

A salt is a random value added to a password before it is converted into a hash. This makes the final hash different even if two users use the same password.

It protects against Rainbow Table attacks because rainbow tables contain precomputed hashes of common passwords. When a salt is used, the attacker cannot use one ready-made table for all hashes. They would need to create a new rainbow table for each unique salt, which takes much more time and storage.

Scenario 3 | Network Traffic Analysis with Wireshark

Scenario 3 | Task Phase 1

The Wireshark filter most effective for isolating the username and password sent via an unencrypted web form is,

```
http.request.method == "POST"
```

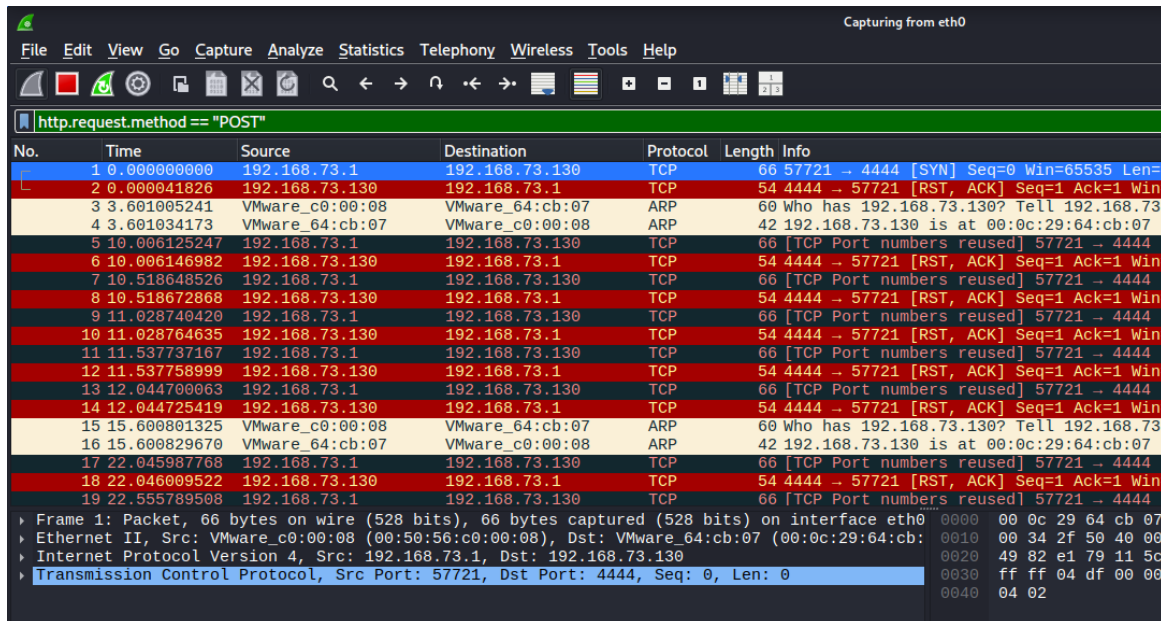


Figure 7 — Wireshark capture filtered by HTTP POST requests

Scenario 3 | Task Phase 2

For a normal HTTP login form, the encoding is usually:

```
application/x-www-form-urlencoded
```

To view plaintext in Wireshark:

1. Click the HTTP POST packet.
2. Expand Hypertext Transfer Protocol.
3. Look for HTML Form URL Encoded or form parameters.
4. Wireshark will show fields like username and password in readable form.

Another easy method:

Right-click packet → Follow → **TCP Stream**

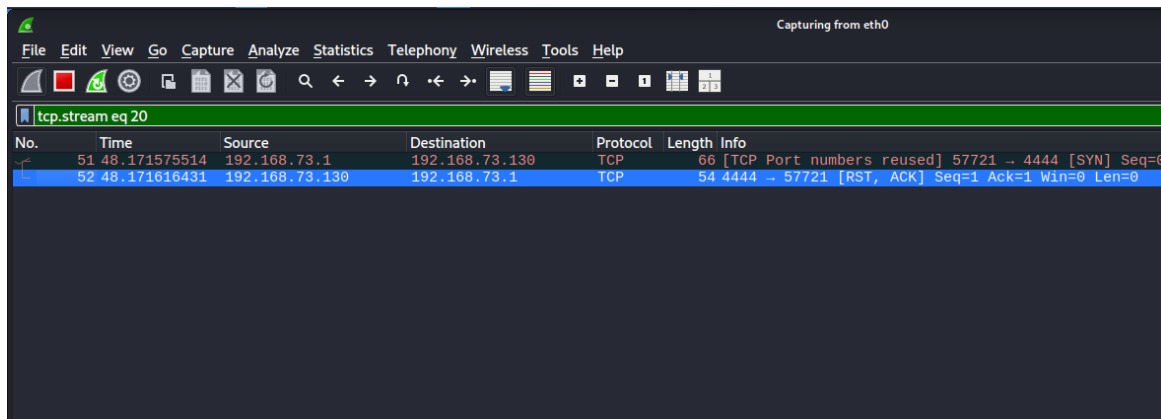


Figure 8 — Follow TCP Stream view of the captured session

Scenario 3 | Task Phase 3

The packet type is:

- Gratuitous ARP

It means a host is announcing an IP-to-MAC address mapping without waiting for an ARP request.

For a defender, repeated or suspicious Gratuitous ARP packets may indicate:

- ARP spoofing / ARP poisoning / Man-in-the-Middle activity

But it can also happen in legitimate cases, such as:

- DHCP updates
- IP conflict detection
- High-availability failover

Scenario 3 | Task 4

The Wireshark feature that allows to see the entire FTP session (USER, PASS, LIST, etc.) in a single, continuous window is:

Follow TCP Stream

This lets users see the full FTP control session, including commands like:

- USER
- PASS
- LIST
- CWD
- RETR

- STOR